

CSW Proof-of-Value Findings — customer1

Generated 2026-05-01T18:30:00Z from live evidence in `https://csw.customer1.example`. Use this as the talk-track for the readout meeting; it is intentionally denser than the CISO brief.

What we looked at

In a single read of the tenant we collected:

Signal	Count
Workloads inventoried	1,880
Workloads reporting via agent	1,206 (64.1%)
Scopes in hierarchy	18
Policies authored	84
Policies in enforce mode	22
Absolute policies (highest precedence)	4
Critical CVEs on workloads	19
High CVEs on workloads	142
Enforcement alerts in 24h	187

The same evidence bundle is replayable; nothing here was hand-curated.

Posture at a glance

Score: 29 / 100 (Grade F)

- **Visibility — 16 pts.** 1206/1880 workloads reporting (64.1% agent coverage).
 - **Segmentation — 6 pts.** 84 policies, 22 in enforce mode (26%), 4 absolute (5%).
 - **Hygiene — 3 pts.** 19 critical, 142 high CVEs detected on workloads.
 - **Operations — 1 pts.** 187 enforcement alerts in last 24h.
 - **Compliance — 3 pts.** 7/25 controls marked 'met' across 4 frameworks.
-

What you're already doing well

Evidence collected for 4 frameworks

Re-using a single set of CSW evidence across multiple frameworks is the headline value proposition - this tenant is realising it.

Compliance reinforcement. This capability supports:

- **HIPAA** — 164.308(a)(1)(ii)(A) (marked met in this collection); 164.312(b) (marked met in this collection)
 - **PCI-DSS** — 1.2.1 (marked met in this collection)
 - **NIST-800-53** — AU-2 (marked met in this collection); RA-5 (marked met in this collection); SI-4 (marked met in this collection)
 - **SOC2** — CC7.1 (marked met in this collection)
-

What we'd recommend addressing

Why these matter beyond the score. The 6 items below together touch **38 not-yet-met controls** across **4 frameworks** (HIPAA, PCI-DSS, NIST-800-53, SOC2). Each item lists the specific control IDs it would help close, so the work can be tracked back to a compliance line item.

62 policies remain in monitor mode

Category: segmentation · Estimated posture uplift if addressed: +11 pts

Monitor-mode policies generate evidence but do not block lateral movement. Promoting reviewed policies to enforce directly improves the segmentation score component.

Compliance impact if addressed. Closing this gap helps move:

- **HIPAA** — 164.308(a)(4) (information access management is enforced via policy); 164.312(a)(1) (access control is implemented as policy); 164.312(e)(1) (transmission security relies on segmentation)
- **PCI-DSS** — 1.3 (no direct internet access to CDE requires enforced policy); 12.5.3 (segmentation effectiveness is tested annually)
- **NIST-800-53** — AC-3 (access enforcement is implemented as policy); AC-4 (information flow enforcement is the segmentation control); CM-7 (least functionality limits flows to what is needed); SC-7 (boundary protection is segmentation); SC-7(5) (deny-by-default requires absolute policies)
- **SOC2** — CC6.1 (logical access is implemented as enforced policy); CC6.6 (boundary protection is segmentation in cloud workloads)

674 workloads without an agent

Category: visibility · Estimated posture uplift if addressed: +9 pts

Workloads outside agent coverage are invisible to flow analytics, ADM, and policy enforcement. Closing this gap unlocks visibility-driven controls in every framework.

Compliance impact if addressed. Closing this gap helps move:

- **HIPAA** — 164.310(c) (workstation security depends on inventory)
- **PCI-DSS** — 11.3 (penetration-test scope is set by inventory)

- **SOC2** — CC6.1 (logical access requires knowing the systems in scope); CC7.2 (system monitoring requires complete telemetry)

19 critical CVEs on workloads

Category: hygiene · Estimated posture uplift if addressed: +9 pts

CSW correlates package CVEs to running processes. Each critical CVE on an internet-reachable workload is a candidate for escalation to patching or compensating policy.

Compliance impact if addressed. Closing this gap helps move:

- **PCI-DSS** — 6.4.2 (production systems must be protected from known CVEs); 11.3 (vulnerability scanning evidence drives this control)

Few absolute policies in place

Category: segmentation · Estimated posture uplift if addressed: +6 pts

Absolute policies are the right tool for crown-jewel isolation (PHI, cardholder data, regulated systems). Their absence indicates the segmentation strategy is still permissive-by-default.

Compliance impact if addressed. Closing this gap helps move:

- **HIPAA** — 164.308(a)(4) (information access management is enforced via policy); 164.312(a)(1) (access control is implemented as policy); 164.312(e)(1) (transmission security relies on segmentation)
- **PCI-DSS** — 1.3 (no direct internet access to CDE requires enforced policy); 12.5.3 (segmentation effectiveness is tested annually)
- **NIST-800-53** — AC-3 (access enforcement is implemented as policy); AC-4 (information flow enforcement is the segmentation control); CM-7 (least functionality limits flows to what is needed); SC-7 (boundary protection is segmentation); SC-7(5) (deny-by-default requires absolute policies)
- **SOC2** — CC6.1 (logical access is implemented as enforced policy); CC6.6 (boundary protection is segmentation in cloud workloads)

187 enforcement alerts in 24h

Category: operations · Estimated posture uplift if addressed: +5 pts

Sustained alert volume indicates either policy gaps (legitimate flows blocked) or active attack pressure. Both warrant SOC engagement and policy review.

Compliance impact if addressed. Closing this gap helps move:

- **HIPAA** — 164.308(a)(5)(ii)(B) (security incident procedures depend on alert hygiene)
- **PCI-DSS** — 10.2 (logging requirements include enforcement events)
- **SOC2** — CC7.2 (system monitoring includes alert tuning)

HIPAA: 5 controls not marked met

Category: compliance · Estimated posture uplift if addressed: +2 pts

5 controls in the HIPAA catalog still show partial or pending evidence. Address these before the next audit cycle.

Compliance impact if addressed. Closing this gap helps move:

- **HIPAA** — 164.308(a)(4) (currently not marked met); 164.308(a)(5)(ii)(B) (currently not marked met); 164.310(c) (currently not marked met); 164.312(a)(1) (currently not marked met); 164.312(e)(1) (currently not marked met)
-

Suggested 30-day plan

The plan is sequenced so each week's work feeds the next; weeks 1-2 are foundation moves, week 3 is the highest-leverage policy promotion, and week 4 closes the loop with a re-measurement.

Wk	Action	Owner	Addresses
1	Close agent-coverage gap. Identify the 674 workloads without an agent. Triage into: (a) deploy now, (b) excluded by policy, (c) decommission. Track in a single ticket; aim for 95%+ coverage.	Platform Engineering	674 workloads without an agent
2	Promote vetted policies to enforce mode. Run the 30-day flow review on monitor-mode policies for top 3 scopes. Promote those with no false-positive flow violations to enforce.	Security Operations	62 policies remain in monitor mode
3	Author absolute	Security	Few absolute

Wk	Action	Owner	Addresses
	policies for crown jewels. Identify the top 3 crown-jewel scopes (databases of regulated data, payment systems, PHI stores). Draft absolute policies that take precedence over inherited rules.	Architecture	policies in place
4	Address top critical CVEs. Pull the CSW vulnerability dashboard, sort by internet exposure + severity, dispatch top 10 to patching or compensating-policy workstreams.	Vulnerability Management	19 critical CVEs on workloads
5	Tune enforcement alert noise. Categorise the past 24h of alerts (legitimate block, missing exception, real attack). Build exception rules for the first two; route the third into incident response.	Security Operations	187 enforcement alerts in 24h
6	Refresh evidence and report. Re-run csw-insights against the tenant. Compare posture score to baseline;	Compliance / GRC	—

Wk	Action	Owner	Addresses
	share delta with steering committee.		

How CSW shows up across the frameworks you care about

For each framework below, the runbooks and reports in CSW-Compliance-Mapping walk through the specific controls this evidence supports. The numbers here are the *current* state of controls evaluated in this tenant.

Framework	Controls evaluated	Met	Coverage
HIPAA	7	2	29%
PCI-DSS	6	1	17%
NIST-800-53	8	3	38%
SOC2	4	1	25%

Demo-able artefacts

The same evidence bundle that produced this report can also drive:

- **ADM (Application Dependency Mapping) walk-through** — visualise the highest-blast-radius workloads we identified.
- **Policy what-if** — replay 24h of flow data against a candidate policy to show enforcement impact before promoting.
- **Vulnerability dashboard** — sort the critical CVEs above by internet exposure to pick the top 10 patching candidates.
- **Auditor-ready evidence bundle** — the signed JSON used to render this report drops directly into the framework runbooks.

What we'd like to do next

1. Walk through the top 3 risks above with your platform/security teams.
2. Pick one risk to address this sprint; re-run `csw-insights` after.
3. Use the resulting before/after delta as the proof point for the wider rollout business case.

Materials, scripts, and templates are in CSW-Tenant-Insights. The underlying compliance narrative is in CSW-Compliance-Mapping. The evidence collection runs from CSW-API-Compliance-Automation.